Entra Privileged Identity Management (PIM) — Just-in-Time Admin

Implementation Solution Guide

Version 1.0.0 · 2026-07-09

Contents

Executive Summary — Entra Privileged Identity Management (PIM): Just-in-Time Admin 5

What you get . . . 5

What this delivers . . . 5

The standard deployment model . . . 5

Outcome . . . 5

1. Solution Overview — Entra Privileged Identity Management (PIM) 6

The problem PIM solves: standing privilege . . . 6

Eligible vs. active assignments . . . 6

The activation policy — the conditions on elevation . . . 6

Entra roles vs. Azure resource roles . . . 6

Access reviews for privileged roles . . . 7

Break-glass (emergency access) accounts . . . 7

What you can control . . . 7

Benefits . . . 7

Limitations (be honest with buyers) . . . 7

The standard deployment model . . . 8

2. Requirements Guide — Entra Privileged Identity Management (PIM) 8

2.1 Microsoft Entra ID P2 licensing . . . 8

2.2 Administrative roles for the operator . . . 8

2.3 Break-glass (emergency access) accounts — MANDATORY FIRST . . . 8

2.4 Standing-access baseline (discovery) . . . 9

2.5 Approver groups and pilot cohort . . . 9

2.6 Activation policy decision . . . 9

2.7 Microsoft Graph PowerShell SDK . . . 9

2.8 Azure RBAC access for resource-role PIM (if in scope) . . . 10

Checklist . . . 10

Global Requirements — Entra ID Solutions (category-level) 10

G1. Microsoft Entra ID tenant . . . 10

G2. Entra ID licensing (P1, P2 where noted) . . . 10

G3. Administrative roles . . . 11

G4. Break-glass (emergency access) accounts . . . 11

G5. Healthy on-premises Active Directory . . . 11

G6. An Entra Connect host server . . . 11

G7. UPN / domain hygiene . . . 11

G8. Network access to Microsoft cloud endpoints . . . 11

3. Implementation Guide — Entra Privileged Identity Management (PIM) 12
Step 1 — Protect the break-glass accounts (do this first) . . . 12
Step 2 — Discover standing privileged access . . . 12
Step 3 — Set the activation policy per role (role settings) . . . 12
Step 4 — Create eligible assignments for the pilot cohort . . . 13
Step 5 — Remove the matching standing (active) assignments — staged . . . 13
Step 6 — Validate activation end-to-end (pilot) . . . 13
Step 7 — Add access reviews for privileged roles . . . 14
Step 8 — Onboard Azure resource roles (if in scope) . . . 14
Step 9 — Expand tenant-wide, with alerts on a schedule . . . 14
5. Testing Guide — Entra Privileged Identity Management (PIM) 15
Test 1 — Standing-access baseline is complete . . . 15
Test 2 — Break-glass accounts are protected . . . 15
Test 3 — Activation policy is set correctly . . . 15
Test 4 — Just-in-time activation works . . . 15
Test 5 — Approval gate works (Tier-0) . . . 15
Test 6 — No standing privilege remains for the pilot cohort . . . 15
Test 7 — Activation is audited . . . 16
Test 8 — Access review runs . . . 16
Pass/fail gate . . . 16
6. Troubleshooting Guide — Entra Privileged Identity Management (PIM) 16
A. PIM is not available / features greyed out . . . 16
B. Discovery or report errors / returns nothing . . . 17
C. A user cannot activate a role . . . 17
D. Admin got locked out after removing standing access . . . 17
E. Break-glass account is at risk . . . 17
F. Activation policy not enforcing . . . 18
G. Access review not removing stale eligibility . . . 18
H. Diagnostics quick reference . . . 18
I. When to escalate . . . 18
7. Best Practices — Entra Privileged Identity Management (PIM) 18
Where to go next . . . 19
8. Deliverables Summary — Entra Privileged Identity Management (PIM) 20
Documentation . . . 20
PowerShell scripts . . . 20
What the buyer receives . . . 21

Outcome 21
Appendix A — PowerShell Scripts 22

Executive Summary — Entra Privileged Identity Management (PIM): Just-in-Time Admin

White-label · Entra ID Solutions

Every permanent Global Administrator in your tenant is a breach that has not happened yet. Standing privileged access — an admin role that is always active, on an account that is always signed-in-able — is the single richest target in Microsoft Entra: steal that one credential and the attacker owns the directory, with no time limit, no approval, and no one watching. Most tenants accumulate far more standing privilege than anyone realizes, because roles are handed out permanently "to be safe" and never taken back.

This is a complete, deploy-it-today package for eliminating standing privileged access with Microsoft Entra Privileged Identity Management (PIM), written for an administrator with no prior PIM experience. It turns always-on admin roles into *eligible* assignments that a person must activate just-in-time — with MFA, a business justification, approval where warranted, and an automatic expiry — and it puts every activation under audit and access review.

What you get

• A plain-language Solution Overview of the PIM model — eligible vs. active assignments, activation policy (MFA, approval, justification, max duration), Entra roles vs. Azure resource roles, access reviews, and break-glass design.

• A Requirements Guide with verify / implement-if-missing for every prerequisite (including the Entra ID P2 licensing PIM requires — *verify current availability in your tenant*).

• An Implementation Guide of precise, click-by-click steps in the required order — discover standing access, onboard roles to PIM, set activation policy, convert to eligible, add access reviews and alerts, pilot-first.

• Five PowerShell scripts (Microsoft.Graph) for standing-access discovery, activation-policy validation, an activation/audit report, safe conversion of active assignments to eligible, and an alerting/break-glass check.

• Testing and Troubleshooting guides for a confident, staged rollout with break-glass protection.

What this delivers

Zero standing privilege — privileged roles are eligible-not-active, every admin action is activated just-in-time with MFA, justification, and approval, time-bound so it auto-expires, reviewed on a recurring cadence, and fully audited — with break-glass accounts kept ready so hardening the identity plane never locks you out.

The standard deployment model

Assess -> Configure -> Pilot -> Validate -> Expand.

Outcome

The biggest identity risk in the tenant closed: no permanent admins, every privileged activation approved, time-bound, and auditable — proven on a pilot cohort before you touch tenant-wide roles, and protected end-to-end by break-glass accounts.

1. Solution Overview — Entra Privileged Identity Management (PIM)

The problem PIM solves: standing privilege

A privileged role assignment is *standing* (or "active") when the account holds it all the time — signed in or not, using it or not. Standing Global Administrators, Privileged Role Administrators, Security Administrators, and the like are the highest-value targets in the tenant: one stolen or phished credential yields permanent, unmonitored, tenant-wide control. The fix is not to remove the people who need admin — it is to remove the *standing* nature of their access, so the power exists only in the moment it is used, under conditions you control.

Eligible vs. active assignments

PIM introduces a second kind of assignment.

- An **active** assignment is the classic one — the role is on the account now.
- An **eligible** assignment means the person is *allowed to* hold the role but does not hold it until

they **activate** it. Activation is an explicit, logged action that grants the role for a bounded window (for example up to 8 hours), after which it automatically expires and the account returns to having no privilege.

The goal state is: privileged roles are assigned **eligible, not active**. Day to day the admin has no elevated rights; when they need to do admin work they activate, do the work, and the role expires on its own.

The activation policy — the conditions on elevation

Each role in PIM has a **role setting** (activation policy) that governs how eligible users activate it. The controls that matter:

- **Require MFA on activation** — a fresh multi-factor challenge at the moment of elevation.
- **Require justification** — the activator types a business reason, captured in the audit log.
- **Require approval** — a named approver must approve the activation before the role is granted

(use this for the most powerful roles, e.g. Global Administrator).

- **Require ticket information** — tie the elevation to a change/incident ticket.
- **Maximum activation duration** — the time-box (e.g. 1–8 hours) after which the role auto-expires.
- **Notifications** — alert admins and the user on eligible assignment, activation, and approval.

Entra roles vs. Azure resource roles

PIM governs two distinct scopes, and this solution covers both:

• **Microsoft Entra roles** — directory roles like Global Administrator, User Administrator, Exchange Administrator. Managed under PIM -> *Microsoft Entra roles*.

• **Azure resource roles** — RBAC roles like Owner, Contributor, User Access Administrator on management groups, subscriptions, and resource groups. Managed under PIM -> *Azure resources*. These matter because an Azure Owner can be as dangerous as a directory admin.

Access reviews for privileged roles

Eligibility still drifts — people change teams, projects end, access lingers. A PIM **access review** periodically asks reviewers (or the users themselves) to confirm each eligible privileged assignment is still needed; anything not re-attested is removed. This keeps the eligible population honest over time.

Break-glass (emergency access) accounts

Hardening the identity plane can lock you out — an approval loop with no available approver, an MFA method that breaks, a policy misfire. **Break-glass accounts** are two cloud-only emergency Global Administrator accounts that are deliberately **excluded from PIM and from broad Conditional Access/MFA policies** and kept permanently active, with credentials stored offline and sign-ins monitored/alerted. They are the safety net that makes it safe to remove everyone else's standing access. Designing and protecting them is part of this solution, not an afterthought.

What you can control

• Discovery: every standing (active) privileged role assignment in Entra and in Azure resources.

• Eligibility: convert standing assignments to eligible so no one holds privilege by default.

• Activation policy: MFA, justification, approval, ticketing, and max-duration per role.

• Access reviews: recurring re-attestation of privileged eligibility.

• Break-glass: two protected emergency accounts, excluded and monitored.

• Audit and alerting: every activation logged; alerts for risky patterns (too many admins, activations without MFA, stale assignments).

Benefits

• Security — the number-one payoff: no permanent admins to steal; every elevation is approved, time-bound, and logged, collapsing the attacker's window from "forever" to "a few hours, if approved".

• Compliance — demonstrable least-privilege and access-review evidence for auditors.

• Visibility — a real inventory of who *could* be an admin and who *actually* elevated, when, and why.

• Repeatability — a governance pattern (reviews, alerts, reports) you run on a schedule, not once.

Limitations (be honest with buyers)

• PIM requires **Microsoft Entra ID P2** (or an equivalent bundle such as Microsoft Entra ID

Governance / certain E5 suites). *Verify current licensing and availability in your tenant.*

• Removing standing access badly can lock admins out — this is why break-glass accounts come first, every change is piloted, and the conversion script defaults to a preview (`-WhatIf`).

• PIM governs *who can activate a role and how*; it does not replace Conditional Access, identity protection, or a broader zero-trust program — it is the privileged-access pillar of it.

The standard deployment model

> *Discover standing privileged access -> configure activation policy and break-glass -> pilot on a cohort of roles/admins (eligible + policy) -> validate activation, approval, and audit -> expand to all privileged roles and Azure resource roles, with access reviews and alerts on a schedule. Repeatable pattern: Assess -> Configure -> Pilot -> Validate -> Expand.*

2. Requirements Guide — Entra Privileged Identity Management (PIM)

Verify every requirement before configuring. Each entry: Description / Why / Verify / Implement-if-missing. Category-wide prerequisites are in `global-requirements-entra-id-solutions.md`.

2.1 Microsoft Entra ID P2 licensing

Description: Microsoft Entra ID P2 for every user who will hold an eligible PIM assignment or act as an approver (P2 is also included in Microsoft Entra ID Governance and certain E5 suites). Why: PIM — eligible assignments, activation policy, access reviews, and PIM alerts — is a P2 feature. A P1-only tenant cannot use it. Verify: M365 admin center -> `Billing -> Licenses`; confirm Microsoft Entra ID P2 seats and free count. In Entra -> `Identity governance -> Privileged Identity Management`, PIM is available. *Entra ID P2 licensing and PIM availability vary by tenant and program — verify current availability in your tenant.* Implement: Assign Microsoft Entra ID P2 (or a suite that includes it) to the admins and approvers who will use PIM before onboarding roles.

2.2 Administrative roles for the operator

Description: `Privileged Role Administrator` (or `Global Administrator`) to configure PIM — onboard roles, set activation policy, and create assignments and reviews. Why: Only these roles can manage role settings and eligible/active assignments in PIM. Reading state for discovery needs only a read role, but configuration needs Privileged Role Administrator. Verify: Entra -> `Roles and administrators`; confirm `Privileged Role Administrator` (with a `Global Administrator` available for the tenant-wide first-time PIM onboarding). Implement: Assign `Privileged Role Administrator` to the operator; reserve `Global Administrator` for the one-time onboarding and for emergency use.

2.3 Break-glass (emergency access) accounts — MANDATORY FIRST

Description: Two cloud-only emergency Global Administrator accounts (`bg-admin-01@contoso.onmicrosoft.com`, `bg-admin-02@contoso.onmicrosoft.com`),

permanently active, excluded from PIM and from broad Conditional Access / MFA policies, with sign-in alerts. Why: PIM removes standing access from everyone else. If an activation, approval, or MFA path breaks, the break-glass accounts are how you get back in. They are the prerequisite that makes the rest safe. Verify: Entra -> `Users`; two cloud-only `@onmicrosoft.com` Global Administrators exist with strong stored credentials; a sign-in alert is configured (see global requirement G4). Run `ENTPIM-Alerting.ps1`. Implement: Create the two accounts, keep them permanently active (do **not** make them PIM-eligible), exclude them from broad CA/MFA policies, store credentials offline and split, and alert on any sign-in.

2.4 Standing-access baseline (discovery)

Description: A repeatable inventory of every current standing (active) privileged role assignment — Entra directory roles and Azure resource roles — with the account, role, and scope. Why: You cannot convert to eligible what you have not inventoried; tenants almost always hold more standing admins than expected. Verify: Run `ENTPIM-Discovery.ps1`; confirm it lists active privileged assignments for Entra roles (and Azure resource roles where in scope) with account and role. Implement: Install the Microsoft Graph PowerShell SDK (see 2.7) and run `ENTPIM-Discovery.ps1`.

2.5 Approver groups and pilot cohort

Description: An approver group `PIM Privileged Role Approvers - Tenant - Steady` for approval-gated roles, and a pilot cohort `PIM Pilot Admins - Pilot - Pilot` of representative admins to onboard first. Why: Approval requires named approvers; the pilot cohort is how every change is validated before it reaches all privileged roles. Verify: Entra -> `Groups`; both groups exist with members. Run `ENTPIM-Validate.ps1` to confirm approvers are set on approval-gated roles. Implement: Create the two groups; add trusted senior admins to the approver group and a handful of representative admins to the pilot cohort.

2.6 Activation policy decision

Description: A documented decision, per privileged role tier, of the activation conditions — which roles require approval, the max activation duration, and whether ticket information is required. Why: These are governance choices, not technical defaults. The most powerful roles (Global Administrator, Privileged Role Administrator) warrant approval + short duration; broadly used roles may need MFA + justification only. Verify: A written tiering exists (e.g. Tier-0 roles = approval + 4h; others = MFA + justification + 8h). Implement: Decide the tiering with the security owner in Implementation Step 3. *Approval, duration, and ticketing choices are the customer's security/operations decision — this guide provides the technical controls, not the policy determination.*

2.7 Microsoft Graph PowerShell SDK

Description: The Microsoft Graph PowerShell SDK on the operator workstation, with consent to the PIM and role-management scopes the scripts use. Why: Discovery, validation, reporting, conversion, and the alerting check read and (for conversion) write PIM eligibility and policy through Microsoft Graph. Verify: `Get-Module -ListAvailable Microsoft.Graph.Identity.Governance` returns a version; a test `Connect-MgGraph` succeeds. Implement: `Install-Module Microsoft.Graph -Scope CurrentUser`; the scripts request least privilege — read: `RoleManagement.Read.All`, `RoleManagementPolicy.Read.AzureADGroup`, `PrivilegedAccess.Read.AzureAD`,

`Directory.Read.All`; and — only for conversion — `RoleManagement.ReadWrite.Directory`. *Verify current Graph scope names for PIM in your tenant.*

2.8 Azure RBAC access for resource-role PIM (if in scope)

Description: For onboarding Azure resource roles, `Owner` or `User Access Administrator` on the target management group / subscription so PIM can be discovered and configured for Azure resources. Why: Azure resource-role PIM is managed at the resource scope, separate from directory roles. Verify: Azure portal -> the subscription/management group -> `Access control (IAM)`; confirm the operator's role. PIM for Azure resources appears under `Identity governance -> PIM -> Azure resources`. Implement: Grant `User Access Administrator` at the appropriate scope; onboard the subscription to PIM.

Checklist

- Microsoft Entra ID P2 assigned to PIM users and approvers (*verify availability*)
- `Privileged Role Administrator` assigned; `Global Administrator` available for onboarding
- Two break-glass accounts created, excluded from PIM/broad policies, and sign-in alerted — FIRST
- Standing-access baseline produced — `ENTPIM-Discovery.ps1`
- Approver group + pilot cohort created
- Activation-policy tiering decided and documented
- Microsoft Graph PowerShell SDK installed and consented
- Azure RBAC access in place if resource-role PIM is in scope

Global Requirements — Entra ID Solutions (category-level)

These requirements apply to every solution in the Entra ID Solutions category. They are published once at the category level so individual listings stay small. Confirm these before deploying any identity solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *The identity plane is high risk. A mistake here breaks sign-in for everyone, so every change is staged and a break-glass account is kept ready before you touch anything.*

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID tenant. Why: It is the cloud identity backbone every other identity service builds on. Verify: Sign in to `https://entra.microsoft.com` as an administrator. Implement: Create a Microsoft 365 or Azure subscription, which provisions a tenant.

G2. Entra ID licensing (P1, P2 where noted)

Description: Microsoft Entra ID P1 (or P2 for risk-based and PIM features). Why: Hybrid features such as seamless sign-in, password writeback, and Conditional Access require P1+. Verify: M365 admin center ->

`Billing -> Licenses`; confirm Entra ID P1/P2 (often bundled in M365 E3/E5 or EMS). Implement: Assign M365 E3/E5, EMS E3/E5, or standalone Entra ID P1/P2.

G3. Administrative roles

Description: Hybrid Identity Administrator and Global Administrator for the operator. Why: Configuring directory synchronization and authentication methods needs these elevated roles. Verify: Entra -> `Roles and administrators`; confirm `Hybrid Identity Administrator` (and a Global Administrator for the one-time first-sync consent). Implement: Assign `Hybrid Identity Administrator`; reserve `Global Administrator` for tenant-wide and first-sync changes.

G4. Break-glass (emergency access) accounts

Description: At least two cloud-only emergency access accounts, excluded from Conditional Access and MFA-broad policies. Why: If sync, federation, or an auth-method change locks out admins, break-glass accounts get you back in. Verify: Entra -> `Users`; confirm two cloud-only accounts (`@onmicrosoft.com`) with strong stored credentials and documented use. Implement: Create two cloud-only Global Administrator accounts; exclude them from policies; store credentials securely and monitor sign-ins.

G5. Healthy on-premises Active Directory

Description: A functional AD forest/domain with healthy replication and DNS. Why: Synchronization reads from AD; replication or DNS faults corrupt or stall the sync. Verify: Run `dcdiag` and `repadmin /replsummary` on a domain controller with no errors; run `HYBID-Discovery.ps1`. Implement: Resolve AD replication, DNS, and time-sync issues before synchronizing.

G6. An Entra Connect host server

Description: A domain-joined Windows Server (2016+), patched, for Microsoft Entra Connect Sync (or a lightweight host with the Cloud Sync agent). Why: Connect Sync runs as a service on this host and must reach both AD and Entra ID. Verify: A supported, domain-joined server with TLS 1.2, .NET, and PowerShell available; run `HYBID-Discovery.ps1`. Implement: Provision a dedicated server (not a domain controller for production), patch it, and enable TLS 1.2.

G7. UPN / domain hygiene

Description: User principal names use a public, verified, routable domain (not `.local`). Why: A non-routable UPN suffix produces sign-in problems and `onmicrosoft.com` fallbacks in the cloud. Verify: Entra -> `Identity -> Settings -> Domain names` shows the public domain Verified; AD UPN suffixes match it; run `HYBID-Discovery.ps1`. Implement: Add and verify the public domain in Entra; add the matching UPN suffix in AD and update user UPNs.

G8. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS (443) from the Connect host to Entra ID, plus required Microsoft 365 service URLs. Why: Synchronization, authentication-agent traffic, and tokens depend on these endpoints. Verify: From the Connect host, reach `https://login.microsoftonline.com` and the Microsoft 365 published URL/IP ranges. Implement: Allow the Microsoft 365 / Entra service URLs and IP ranges through

the proxy/firewall.

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

3. Implementation Guide — Entra Privileged Identity Management (PIM)

Follow these steps in order. Most steps are in the Microsoft Entra admin center (`https://entra.microsoft.com` -> `Identity governance -> Privileged Identity Management`); discovery, validation, and conversion use the included scripts.

> *Model: protect break-glass first, discover standing access, set activation policy, convert a pilot cohort of roles to eligible, validate activation and audit, then expand to all privileged roles and Azure resource roles with access reviews and alerts. Every change is staged and reversible, and break-glass accounts stay excluded throughout.*

Step 1 — Protect the break-glass accounts (do this first)

1. Entra -> `Users`. Confirm two cloud-only accounts exist:

`bg-admin-01@contoso.onmicrosoft.com` and `bg-admin-02@contoso.onmicrosoft.com`, each with the Global Administrator role assigned **permanently active (not via PIM)**.

1. Exclude both from broad Conditional Access and MFA-enforcement policies (they keep a strong, separately stored credential instead).

1. Create a sign-in alert for both accounts. Run `ENTPIM-Alerting.ps1` to confirm they are excluded from PIM and that alerting is in place. **Never** make a break-glass account PIM-eligible.

Step 2 — Discover standing privileged access

1. Entra -> `Identity governance -> Privileged Identity Management -> Microsoft Entra roles -> Assignments -> Active assignments` to see who holds directory roles now.

1. Run `ENTPIM-Discovery.ps1`. It lists every active privileged assignment — account, role, and whether it is permanent — for Entra roles, and (with `-IncludeAzureResources`) Azure resource roles. Save the output; it is your baseline and your conversion worklist.

1. Flag the standing Global Administrators especially — Microsoft recommends keeping the number of permanent Global Administrators very small (break-glass only). *Verify current guidance in your tenant.*

Step 3 — Set the activation policy per role (role settings)

1. Entra -> `Privileged Identity Management -> Microsoft Entra roles -> Settings`. Open a role you will onboard (start with a lower-risk role for the pilot, e.g. `User Administrator`).

1. Click `Edit` and set, per your Step 2.6 tiering:

• `Activation` -> maximum duration (e.g. 8 hours for standard roles; 4 hours for Tier-0).

• `Require Azure AD Multi-Factor Authentication on activation` -> On.

• `Require justification on activation` -> On.

• `Require ticket information on activation` -> On for change-controlled roles (optional).

• `Require approval to activate` -> On for Tier-0 roles; set approvers to `PIM Privileged Role Approvers - Tenant - Steady`.

• `Notification` -> enable alerts to admins on eligible assignment and activation.

1. Save. Repeat for each role in scope, most-privileged roles getting approval + shortest duration.

Step 4 — Create eligible assignments for the pilot cohort

1. Entra -> `Privileged Identity Management -> Microsoft Entra roles -> Assignments -> Eligible assignments -> Add assignments`.

1. Select the role, add the members of `PIM Pilot Admins - Pilot - Pilot`, and set the assignment type to `Eligible` with an appropriate eligibility window (e.g. 6–12 months, or per your policy). Assign.

1. Communicate to the pilot admins how to activate (Step 6) before removing their standing access.

Step 5 — Remove the matching standing (active) assignments — staged

1. Preview first: run `ENTPIM-Set-EligibleAssignments.ps1` with its default `-WhatIf`. It reports, for the pilot cohort, the active assignments it would remove now that an eligible assignment exists — nothing is changed, and break-glass accounts are always excluded.

1. Confirm the preview: every pilot admin has an eligible assignment for each role you are about to de-activate, and no break-glass account is in the list.

1. Re-run with `-WhatIf:$false` scoped to the confirmed pilot cohort to remove the standing assignments. To do one in the portal instead: `Active assignments ->` the assignment `-> Remove`.

Step 6 — Validate activation end-to-end (pilot)

1. As a pilot admin: Entra -> `Privileged Identity Management -> My roles -> Microsoft Entra roles -> Activate` the eligible role. Complete MFA, enter the justification (and approval, for Tier-0).

1. Confirm the role is granted for the set duration and that admin work now succeeds.

2. Wait for (or end) the activation and confirm the role auto-expires and privilege is gone.

3. Run `ENTPIM-Report.ps1` and confirm the activation appears in the audit with actor, role, justification, and time. Complete the Testing Guide.

Step 7 — Add access reviews for privileged roles

1. Entra -> `Privileged Identity Management -> Microsoft Entra roles -> Access reviews -> New`.

2. Create `Privileged Role Access Review - Tenant - Quarterly`: scope to the privileged roles, set a

recurring quarterly schedule, reviewers = the role's owners or the approver group, and enable `auto-apply results` so unapproved eligibility is removed.

1. Save and start. Run `ENTPIM-Report.ps1 -AccessReviews` to confirm the review is active.

Step 8 — Onboard Azure resource roles (if in scope)

1. Entra -> `Privileged Identity Management -> Azure resources -> Discover resources`; onboard the

target subscription/management group.

1. Repeat Steps 3–5 for Azure roles (e.g. `Owner`, `Contributor`, `User Access Administrator`): set

role settings (MFA/justification/approval/duration), add eligible assignments, and remove standing ones via `ENTPIM-Set-EligibleAssignments.ps1 -IncludeAzureResources` (preview first).

Step 9 — Expand tenant-wide, with alerts on a schedule

1. Work the full Step 2 baseline in batches — onboard the remaining privileged roles, create eligible

assignments, and remove standing access (preview, confirm, apply) until only break-glass accounts hold permanent Global Administrator.

1. Entra -> `Privileged Identity Management -> Microsoft Entra roles -> Alerts`. Review and enable the

built-in alerts (too many Global Administrators, roles activated too frequently, roles being assigned outside of PIM, no MFA on activation). Run `ENTPIM-Alerting.ps1` on a schedule to report alert state.

1. Re-run `ENTPIM-Discovery.ps1` and `ENTPIM-Report.ps1` monthly so new standing assignments are caught

and activations stay audited.

Order of operations

```
Protect break-glass -> discover standing access -> set activation policy -> eligible assignments (pilot) -> remove standing (pilot) -> validate activation + audit -> access reviews -> Azure resource roles -> expand + alerts
```

Rollback

- Removed a standing assignment in error: re-add it in `Active assignments -> Add assignments`

(immediate). Because conversion is confirmed per account from a `-WhatIf` preview, only reviewed accounts are ever changed, and break-glass accounts are always excluded.

- Activation policy too strict (e.g. no approver available): `Role settings -> Edit` the role and relax approval or duration; changes apply to the next activation.
- Locked out entirely: sign in with a break-glass account and revert the offending policy.

5. Testing Guide — Entra Privileged Identity Management (PIM)

Run after the pilot configuration applies (Implementation Step 6) and on the recurring governance cadence. Keep a break-glass account available throughout.

Test 1 — Standing-access baseline is complete

Do: Run `ENTPIM-Discovery.ps1` (add `-IncludeAzureResources` if Azure roles are in scope). Expected: Every active privileged assignment is listed with account, role, scope, and whether it is permanent — a usable conversion worklist.

Test 2 — Break-glass accounts are protected

Do: Run `ENTPIM-Alerting.ps1`. Expected: Both `bg-admin-01` / `bg-admin-02` are permanently active Global Administrators, are **not** PIM-eligible, are excluded from broad CA/MFA policies, and have a sign-in alert configured.

Test 3 — Activation policy is set correctly

Do: Run `ENTPIM-Validate.ps1`, or check `Microsoft Entra roles -> Settings -> <role>`. Expected: Each onboarded role requires MFA and justification; Tier-0 roles require approval with `PIM Privileged Role Approvers - Tenant - Steady` as approvers; max duration matches the tiering.

Test 4 — Just-in-time activation works

Do: As a pilot admin, activate an eligible role from `My roles`, completing MFA and justification. Expected: The role is granted for the configured window, admin work succeeds, and the role auto-expires at the end — privilege returns to zero with no manual removal.

Test 5 — Approval gate works (Tier-0)

Do: As a pilot admin, request activation of an approval-gated role. Expected: Activation is pending until an approver in `PIM Privileged Role Approvers - Tenant - Steady` approves; on approval the role activates, on denial it does not.

Test 6 — No standing privilege remains for the pilot cohort

Do: Run `ENTPIM-Discovery.ps1` filtered to the pilot cohort after Step 5. Expected: Pilot admins hold the roles as **eligible**, not active; only break-glass accounts still hold permanent Global Administrator.

Test 7 — Activation is audited

Do: Run `ENTPIM-Report.ps1`. Expected: Each activation appears with actor, role, justification, approver (if any), start time, and expiry — an audit trail suitable for compliance evidence.

Test 8 — Access review runs

Do: Run `ENTPIM-Report.ps1 -AccessReviews`, or check `Microsoft Entra roles -> Access reviews`. Expected: `Privileged Role Access Review - Tenant - Quarterly` is active on schedule with reviewers assigned and auto-apply enabled.

Pass/fail gate

Gate	Requirement
Pilot pass	Tests 1–5 pass; the pilot cohort is converted to eligible (Test 6) and an activation is audited (Test 7)
Expand pass	Tests 1–3, 6–8 pass tenant-wide; only break-glass accounts hold permanent Global Administrator; access reviews and alerts are on a schedule

6. Troubleshooting Guide — Entra Privileged Identity Management (PIM)

Use `ENTPIM-Discovery.ps1` for standing-access inventory, `ENTPIM-Validate.ps1` for activation-policy state, `ENTPIM-Report.ps1` for activation audit and access-review status, `ENTPIM-Alerting.ps1` for break-glass and alert state, and `ENTPIM-Set-EligibleAssignments.ps1` (preview first) for safe conversion. Keep a break-glass account available.

A. PIM is not available / features greyed out

Symptom	Cause	Remediation
No PIM node, or eligible assignments unavailable	Tenant lacks Entra ID P2, or the user is unlicensed	Assign Microsoft Entra ID P2 to the operator and PIM users (*verify availability in your tenant*); sign out and back in
Cannot edit role settings or create assignments	Operator lacks `Privileged Role Administrator`	Assign `Privileged Role Administrator` (or use `Global Administrator` for first-time onboarding)

B. Discovery or report errors / returns nothing

Symptom	Cause	Remediation
`Connect-MgGraph` fails or scopes missing	SDK not installed, or PIM read scopes not consented	`Install-Module Microsoft.Graph -Scope CurrentUser`; re-run and accept `RoleManagement.Read.All`, `PrivilegedAccess.Read.AzureAD`, `Directory.Read.All`
Azure resource roles missing from discovery	Subscription not onboarded to PIM, or no Azure RBAC on the scope	Onboard the subscription (`PIM -> Azure resources -> Discover resources`); grant `User Access Administrator`; re-run with `-IncludeAzureResources`
Empty results	Signed in to the wrong tenant	Confirm the tenant; re-run

C. A user cannot activate a role

Symptom	Cause	Remediation
No eligible role shows under `My roles`	The eligible assignment was not created, or it expired	Create/renew the eligible assignment (`Eligible assignments -> Add`); confirm with `ENTPIM-Discovery.ps1`
Activation blocked at MFA	The user has no registered MFA method	Register an MFA method; break-glass excepted, all admins should have phishing-resistant MFA
Activation stuck "pending approval"	No approver available or approver not notified	Ensure `PIM Privileged Role Approvers - Tenant - Steady` has active members and notifications are on; an approver approves in `PIM -> Approve requests`

D. Admin got locked out after removing standing access

- Sign in with a break-glass account (`bg-admin-01@contoso.onmicrosoft.com`). Re-add the needed

assignment under `Active assignments -> Add`, or create/adjust the eligible assignment and relax the activation policy. This is exactly why break-glass accounts are created first and kept excluded.

E. Break-glass account is at risk

Symptom	Cause	Remediation
`ENTPIM-Alerting.ps1` flags a break-glass account as PIM-eligible or policy-covered	It was onboarded to PIM or swept into a CA/MFA policy by mistake	Remove it from PIM eligibility, exclude it from the broad CA/MFA policies, and confirm it is permanently active with a sign-in alert
Unexpected break-glass sign-in	Possible compromise or an untracked use	Investigate immediately via the sign-in alert; rotate the credential; confirm the second break-glass account is intact

F. Activation policy not enforcing

- After editing `Role settings`, confirm you saved and edited the correct role. Policy applies to the **next** activation, not existing active sessions. Run `ENTPIM-Validate.ps1` to read back the effective MFA/justification/approval/duration for each role.

G. Access review not removing stale eligibility

- Confirm the review has `auto-apply results` enabled; without it, decisions are recorded but not enforced. Check reviewers are responding, and that the review scope includes the roles you expect. Run `ENTPIM-Report.ps1 -AccessReviews`.

H. Diagnostics quick reference

```
Connect-MgGraph -Scopes 'RoleManagement.Read.All','PrivilegedAccess.Read.AzureAD','Directory.Read.All' -No
# active (standing) directory-role assignments
Get-MgRoleManagementDirectoryRoleAssignmentScheduleInstance -All
# eligible directory-role assignments
Get-MgRoleManagementDirectoryRoleEligibilityScheduleInstance -All
# activation history (audit)
Get-MgRoleManagementDirectoryRoleAssignmentScheduleRequest -All
# role settings (activation policy) for a role
Get-MgPolicyRoleManagementPolicyAssignment -Filter "scopeId eq '/' and scopeType eq 'DirectoryRole'"
```

I. When to escalate

If a privileged account activated a role in an unexpected pattern (odd hours, no matching change ticket, from an unfamiliar location) — or a break-glass account signed in unexpectedly — treat it as a potential compromise: revoke the account's eligibility and any active assignment, disable the account, rotate its credentials, and engage your incident-response process.

7. Best Practices — Entra Privileged Identity Management (PIM)

- Break-glass first, always. Create, exclude, and alert two cloud-only emergency Global Administrators

before you remove anyone's standing access — and never make them PIM-eligible. They are what makes removing standing privilege safe.

• Drive standing Global Administrators to (almost) zero. Aim for only the break-glass accounts holding permanent Global Administrator; everyone else is eligible-not-active. *Verify current Microsoft guidance on permanent-admin counts in your tenant.*

• Tier your roles and match the policy to the risk. The most powerful roles (Global Administrator, Privileged Role Administrator, Security Administrator) get approval + short duration + MFA + justification; broadly used lower-risk roles can be MFA + justification with a longer window.

• Always require MFA and justification on activation. MFA at the moment of elevation blocks stolen-token reuse; the justification creates the audit narrative.

• Require approval for Tier-0. A second human in the loop for the crown-jewel roles turns a single stolen credential into a blocked request.

• Keep activation windows short. Right-size the maximum duration to the task; a role that auto-expires in hours has a far smaller blast radius than one that lingers a full day.

• Govern Azure resource roles too. An Azure `Owner` can be as dangerous as a directory admin — put Owner/Contributor/User Access Administrator under PIM, not just Entra roles.

• Review eligibility on a cadence. Run the quarterly access review so eligibility that is no longer needed is removed; eligibility drifts as people change teams.

• Turn on and watch the PIM alerts. Too many admins, activations without MFA, roles assigned outside PIM, and stale assignments are early warnings — review them, don't just enable them.

• Stage and preview every removal. Removing standing access can lock out a real admin — always run the conversion in `-WhatIf` preview, confirm each account has an eligible assignment, then apply.

• Make it recurring, not one-time. Re-run discovery and the report monthly so new standing assignments are caught and activations stay audited.

Where to go next

• **Conditional Access** — pair PIM with CA policies that require compliant devices and phishing-resistant MFA for admin activation (see the Entra Conditional Access solutions).

• **Enterprise App & Service Principal Governance** — apps and service principals are the *other* privileged-access path; govern their consent and application permissions alongside human admins.

• **Identity Protection / risk-based access** — feed sign-in and user-risk signals into admin access decisions.

• **Access reviews at scale (Identity Governance)** — extend recurring review beyond privileged roles to group and app access.

8. Deliverables Summary — Entra Privileged Identity Management (PIM)

Documentation

Document	Purpose
Executive Summary	Business case and what is in the box
1. Solution Overview	The PIM model — eligible vs. active, activation policy, Entra vs. Azure resource roles, access reviews, break-glass
2. Requirements Guide	Every prerequisite with Verify / Implement-if-missing (including Entra ID P2)
Global Requirements (Entra ID Solutions)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered steps (break-glass, discover, activation policy, eligible assignments, remove standing, validate, access reviews, Azure roles, expand + alerts)
5. Testing Guide	Validation procedures with pass/fail gates
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations + where to go next

PowerShell scripts

Script	What it does
`ENTPIM-Discovery.ps1`	Inventories standing (active) privileged role assignments for Entra roles and, optionally, Azure resource roles — account, role, scope, permanent-or-not (read-only)
`ENTPIM-Validate.ps1`	Confirms each onboarded role's activation policy (MFA, justification, approval + approvers, max duration) matches the tiering (read-only)
`ENTPIM-Report.ps1`	Activation/audit and access-review report — who activated what, when, with what justification and approval; access-review status (read-only)
`ENTPIM-Set-EligibleAssignments.ps1`	Safely removes standing (active) assignments once an eligible assignment exists; `-WhatIf` by default; always excludes break-glass accounts

Script	What it does
`ENTPIM-Alerting.ps1`	Checks break-glass protection (permanent, not PIM-eligible, excluded, alerted) and reports PIM alert state (read-only)

What the buyer receives

- This implementation guide as a branded Word document and PDF.
- All five PowerShell scripts in a single ZIP.
- A repeatable process: Assess -> Configure -> Pilot -> Validate -> Expand.

Outcome

Zero standing privilege — privileged roles eligible-not-active, every admin action activated just-in-time with MFA, justification, and approval, time-bound and fully audited, reviewed on a schedule, and protected end-to-end by break-glass accounts — proven on a pilot before you scale.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

ENTPIM-Alerting.ps1

Purpose: Read-only safety check. For each break-glass account it confirms the account (1) still holds Global Administrator, (2) holds it as a PERMANENT ACTIVE assignment — not via PIM eligibility, and (3) is NOT listed as PIM-eligible for any role (break-glass must never be behind an activation/approval loop). It also surfaces the current count of permanent Global Administrators as a headline PIM-hygiene signal. Use it after every rollout batch and on a schedule. Configuring sign-in alert rules and PIM alert thresholds is done in the portal; this script reports the state you must keep true. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTPIM-Alerting.ps1 Optional: -BreakGlassUpns 'bg-admin-01@contoso.onmicrosoft.com','bg-admin-02@contoso.onmicrosoft.com' (default) Consents to RoleManagement.Read.All, PrivilegedAccess.Read.AzureAD, Directory.Read.All (read-only). EXPECTED RESULTS PASS/FAIL per break-glass account against the three rules above, plus the permanent-GA count. FAIL means a break-glass account is mis-configured (e.g. made PIM-eligible) — fix immediately. No changes are made. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([string[]]$BreakGlassUpns = @('bg-admin-01@contoso.onmicrosoft.com','bg-admin-02@contoso.onmicrosoft.com'))

How to run: powershell -ExecutionPolicy Bypass -File .\ENTPIM-Alerting.ps1 Optional: -BreakGlassUpns 'bg-admin-01@contoso.onmicrosoft.com','bg-admin-02@contoso.onmicrosoft.com' (default) Consents to RoleManagement.Read.All, PrivilegedAccess.Read.AzureAD, Directory.Read.All (read-only). EXPECTED RESULTS PASS/FAIL per break-glass account against the three rules above, plus the permanent-GA count. FAIL means a break-glass account is mis-configured (e.g. made PIM-eligible) — fix immediately. No changes are made. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([string[]]$BreakGlassUpns = @('bg-admin-01@contoso.onmicrosoft.com','bg-admin-02@contoso.onmicrosoft.com'))

ENTPIM-Discovery.ps1

Purpose: Read-only baseline of standing privileged access. Lists every ACTIVE assignment for Microsoft Entra directory roles — the account, the role, and whether the assignment is permanent (no end date) versus time-bound — so you know exactly what to convert to eligible. With -IncludeAzureResources it also reports active Azure resource-role (RBAC) assignments for onboarded subscriptions. This is your conversion worklist. HOW TO RUN Install-Module Microsoft.Graph -Scope CurrentUser # once powershell -ExecutionPolicy Bypass -File .\ENTPIM-Discovery.ps1 Optional: -IncludeAzureResources include Azure resource-role assignments (needs the Az module + RBAC read) Optional: -CsvPath .\entpim-standing.csv export a flat CSV Consents to RoleManagement.Read.All, PrivilegedAccess.Read.AzureAD, Directory.Read.All (read-only). EXPECTED RESULTS A per-assignment listing of standing privileged access with account, role, and permanence. Permanent Global Administrators are highlighted. No changes are made. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([switch]$IncludeAzureResources, [string]$CsvPath)

How to run: Install-Module Microsoft.Graph -Scope CurrentUser # once powershell -ExecutionPolicy Bypass -File .\ENTPIM-Discovery.ps1 Optional: -IncludeAzureResources include Azure resource-role assignments (needs the Az module + RBAC read) Optional: -CsvPath .\entpim-standing.csv export a flat CSV Consents to RoleManagement.Read.All, PrivilegedAccess.Read.AzureAD, Directory.Read.All

(read-only). EXPECTED RESULTS A per-assignment listing of standing privileged access with account, role, and permanence. Permanent Global Administrators are highlighted. No changes are made. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([switch]$IncludeAzureResources, [string]$CsvPath)

ENTPIM-Report.ps1

Purpose: Read-only reporting for PIM governance evidence. By default it reports recent role ACTIVATIONS (who activated which role, when, the justification, and the approver if any) from the role-assignment schedule requests — an audit trail for compliance. With -AccessReviews it instead reports the status of privileged-role access reviews (name, schedule, whether auto-apply is on). Use it monthly. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTPIM-Report.ps1 Optional: -Days 30 look back window for activations (default 30) Optional: -AccessReviews report access-review status instead of activations Optional: -CsvPath .\entpim-activations.csv export a flat CSV Consents to RoleManagement.Read.All, AccessReview.Read.All, Directory.Read.All (read-only). EXPECTED RESULTS A list of privileged activations with actor, role, justification, approval, and time — or, with -AccessReviews, the active review definitions. No changes are made. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([int]$Days = 30, [switch]$AccessReviews, [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\ENTPIM-Report.ps1 Optional: -Days 30 look back window for activations (default 30) Optional: -AccessReviews report access-review status instead of activations Optional: -CsvPath .\entpim-activations.csv export a flat CSV Consents to RoleManagement.Read.All, AccessReview.Read.All, Directory.Read.All (read-only). EXPECTED RESULTS A list of privileged activations with actor, role, justification, approval, and time — or, with -AccessReviews, the active review definitions. No changes are made. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([int]$Days = 30, [switch]$AccessReviews, [string]$CsvPath)

ENTPIM-Set-EligibleAssignments.ps1

Purpose: The one script that CHANGES the tenant — and it is gated. For a set of accounts (a pilot cohort, then batches), it finds the ACTIVE (standing) privileged directory-role assignments that can be removed BECAUSE the same account already holds an ELIGIBLE assignment for that role. It never removes an active assignment that has no matching eligible assignment, and it NEVER touches accounts on the break-glass exclusion list. By default it only previews (-WhatIf); you must pass -WhatIf:$false to apply. HOW TO RUN 1) Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\ENTPIM-Set-EligibleAssignments.ps1 -PrincipalUpns 'ada@contoso.com','sam@contoso.com' 2) Apply to the confirmed accounts: powershell -ExecutionPolicy Bypass -File .\ENTPIM-Set-EligibleAssignments.ps1 -PrincipalUpns 'ada@contoso.com' -WhatIf:$false Optional: -BreakGlassUpns 'bg-admin-01@contoso.onmicrosoft.com','bg-admin-02@contoso.onmicrosoft.com' (default) Consents to RoleManagement.ReadWrite.Directory, Directory.Read.All. EXPECTED RESULTS Preview: a list of the standing assignments it WOULD remove (each with a confirmed eligible assignment), break-glass accounts explicitly skipped. Apply: those assignments removed; run ENTPIM-Discovery.ps1 to confirm the accounts now hold the roles as eligible only. .NOTES White-label — Entra ID Solutions. Change script — preview-first, break-glass-safe. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([Parameter(Mandatory=$true)][string[]]$PrincipalUpns, [string[]]$BreakGlassUpns = @('bg-admin-01@contoso.onmicrosoft.com','bg-admin-02@contoso.onmicrosoft.com'))

How to run: 1) Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\ENTPIM-Set-EligibleAssignments.ps1 -PrincipalUpns 'ada@contoso.com','sam@contoso.com' 2) Apply to the confirmed accounts: powershell -ExecutionPolicy Bypass -File .\ENTPIM-Set-EligibleAssignments.ps1 -PrincipalUpns 'ada@contoso.com' -WhatIf:$false Optional: -BreakGlassUpns 'bg-admin-01@contoso.onmicrosoft.com','bg-admin-02@contoso.onmicrosoft.com' (default) Consents to RoleManagement.ReadWrite.Directory, Directory.Read.All. EXPECTED RESULTS Preview: a list of the standing assignments it WOULD remove (each with a confirmed eligible assignment), break-glass accounts explicitly skipped. Apply: those assignments removed; run ENTPIM-Discovery.ps1 to confirm the accounts now hold the roles as eligible only. .NOTES White-label — Entra ID Solutions. Change script — preview-first, break-glass-safe. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([Parameter(Mandatory=$true)][string[]]$PrincipalUpns, [string[]]$BreakGlassUpns = @('bg-admin-01@contoso.onmicrosoft.com','bg-admin-02@contoso.onmicrosoft.com'))

ENTPIM-Validate.ps1

Purpose: Read-only check that each onboarded privileged role's activation policy matches your tiering: require MFA on activation, require justification, require approval (with approvers) for Tier-0 roles, and a maximum activation duration. It reads the role-management policy rules through Microsoft Graph and reports PASS/REVIEW per role so you can prove the guardrails are in place. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTPIM-Validate.ps1 Optional: -Tier0Roles 'Global Administrator','Privileged Role Administrator' roles that must require approval Optional: -MaxHours 8 maximum activation duration to expect (Tier-0 may be shorter) Consents to RoleManagementPolicy.Read.AzureADGroup, RoleManagement.Read.All, Directory.Read.All (read-only). EXPECTED RESULTS Per role: whether MFA, justification, approval, and max-duration are configured as expected. REVIEW lines flag roles whose policy does not match the tiering. No changes are made. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([string[]]$Tier0Roles = @('Global Administrator','Privileged Role Administrator','Security Administrator'), [int]$MaxHours = 8)

How to run: powershell -ExecutionPolicy Bypass -File .\ENTPIM-Validate.ps1 Optional: -Tier0Roles 'Global Administrator','Privileged Role Administrator' roles that must require approval Optional: -MaxHours 8 maximum activation duration to expect (Tier-0 may be shorter) Consents to RoleManagementPolicy.Read.AzureADGroup, RoleManagement.Read.All, Directory.Read.All (read-only). EXPECTED RESULTS Per role: whether MFA, justification, approval, and max-duration are configured as expected. REVIEW lines flag roles whose policy does not match the tiering. No changes are made. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([string[]]$Tier0Roles = @('Global Administrator','Privileged Role Administrator','Security Administrator'), [int]$MaxHours = 8)